WHOAMI-LABS.COM

INFORME DE PENETRATION TESTING

Evaluación de seguridad de la API «OrderLeak»

Prueba de concepto de autorización rota a nivel de objeto (BOLA / IDOR)

CONFIDENCIAL

Objetivo: OrderLeak — Shop Orders API

Plataforma: whoami-labs.com (entorno autorizado)

Fecha de la prueba: 26 de octubre de 2026

Analista: Josep Sanz — Proyecto «ciber»

Host: 172.17.0.2:5000 (Gunicorn)

Dificultad: Fácil (1 punto)

Duración: 00h 10m 49s

Versión del informe: 1.0

Aviso de confidencialidad y autorización

Este documento contiene información sensible sobre vulnerabilidades de seguridad y está destinado exclusivamente a su uso interno con fines formativos. Toda la actividad descrita se ha ejecutado dentro de un **entorno de laboratorio aislado y explícitamente autorizado** (plataforma whoami-labs.com), sobre un sistema de prueba efímero. **En ningún momento se ha atacado infraestructura de terceros sin permiso por escrito.** La publicación o reproducción total o parcial fuera del contexto autorizado puede comprometer la seguridad y no está permitida.

1. Resumen ejecutivo

Se ha realizado una prueba de intrusión sobre el servicio web **OrderLeak**, una API de gestión de pedidos expuesta en `http://172.17.0.2:5000`. El objetivo era identificar y explotar debilidades que permitieran el acceso no autorizado a datos.

Durante la evaluación se identificó una vulnerabilidad de **severidad Alta**: una **autorización rota a nivel de objeto (BOLA)**, también conocida como *IDOR* (*Insecure Direct Object Reference*), en el *endpoint* `/api/orders/<id>`. El servicio devuelve el detalle de cualquier pedido a partir de un identificador numérico **sin requerir autenticación ni comprobar la propiedad del recurso**. Un atacante puede enumerar identificadores secuenciales y recuperar pedidos de otros usuarios, incluyendo información marcada como confidencial.

La explotación se confirmó accediendo al pedido `#15`, propiedad del usuario `carol` y marcado como `confidential`, que contenía datos de una adquisición clasificada de infraestructura. El compromiso del laboratorio se completó en menos de 11 minutos, obteniendo la bandera `BURP{bola_comparer_api}`.

Hallazgo principal: BOLA / IDOR en `/api/orders/<id>`
CVSS 3.1: 7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N) · CWE-639 · OWASP API1:2023

7.5
ALTA

2. Alcance y reglas de compromiso

Parámetro	Valor
Alcance (scope)	Host único `172.17.0.2`, servicio TCP/5000 (OrderLeak Shop API)
Tipo de prueba	Caja negra (black-box), sin credenciales previas
Red	Red interna aislada de laboratorio (sin acceso a Internet ni a terceros)
Máquina atacante	Kali Linux
Autorización	Plataforma whoami-labs.com — ataque explícitamente permitido
Fuera de alcance	Cualquier sistema ajeno al host del laboratorio; denegación de servicio

3. Metodología

La evaluación siguió una metodología estándar por fases, alineada con marcos de referencia como OWASP y MITRE ATT&CK:

1. **Reconocimiento y escaneo:** descubrimiento de host, puertos y servicios con Nmap.
2. **Enumeración web:** fuzzing de directorios y rutas con Feroxbuster.
3. **Análisis de la aplicación:** revisión de la documentación del API y de las respuestas del servicio.
4. **Explotación:** abuso de la referencia directa a objetos para acceder a recursos ajenos.
5. **Documentación:** recolección de evidencias e informe.

4. Resumen de hallazgos

ID	Hallazgo	Severidad	Estado
H-01	Autorización rota a nivel de objeto (BOLA / IDOR) en `/api/orders/<id>`	ALTA (7.5)	Confirmado / Explotado
H-02	Documentación de API pública que expone la estructura interna de los endpoints	INFO	Confirmado
H-03	Ausencia total de autenticación en endpoints que sirven datos de negocio	ALTA	Confirmado

5. Desarrollo técnico

5.1 Reconocimiento — escaneo de puertos y servicios

Se realizó un escaneo completo de puertos TCP contra el objetivo, con detección de versiones y scripts por defecto, para identificar la superficie de ataque expuesta:

```
$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

El escaneo reveló un **único puerto abierto**, el `5000/tcp`, sirviendo una aplicación web HTTP sobre el servidor **Gunicorn**. El título de la página, *«OrderLeak — Shop API Demo»*, confirma que se trata de un API de pedidos. El resto de los 65.534 puertos aparecen cerrados, lo que concentra todo el análisis en este servicio.



Figura 1. Resultado de Nmap: puerto 5000/tcp abierto (HTTP / Gunicorn) con el título «OrderLeak Shop API Demo».

5.2 Enumeración web — descubrimiento de rutas

Con el servicio identificado, se enumeraron rutas y directorios mediante fuerza bruta de diccionario con Feroxbuster, probando extensiones comunes:

```
$ feroxbuster -u http://172.17.0.2:5000 -t 5 \
      -x php,bak,txt,html,py,zip \
      -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt
```

La herramienta descubrió tres rutas que responden con código `200 OK`: la raíz (`/`), el endpoint de estado (`/status`) y, lo más relevante, una ruta de documentación (`/docs`).

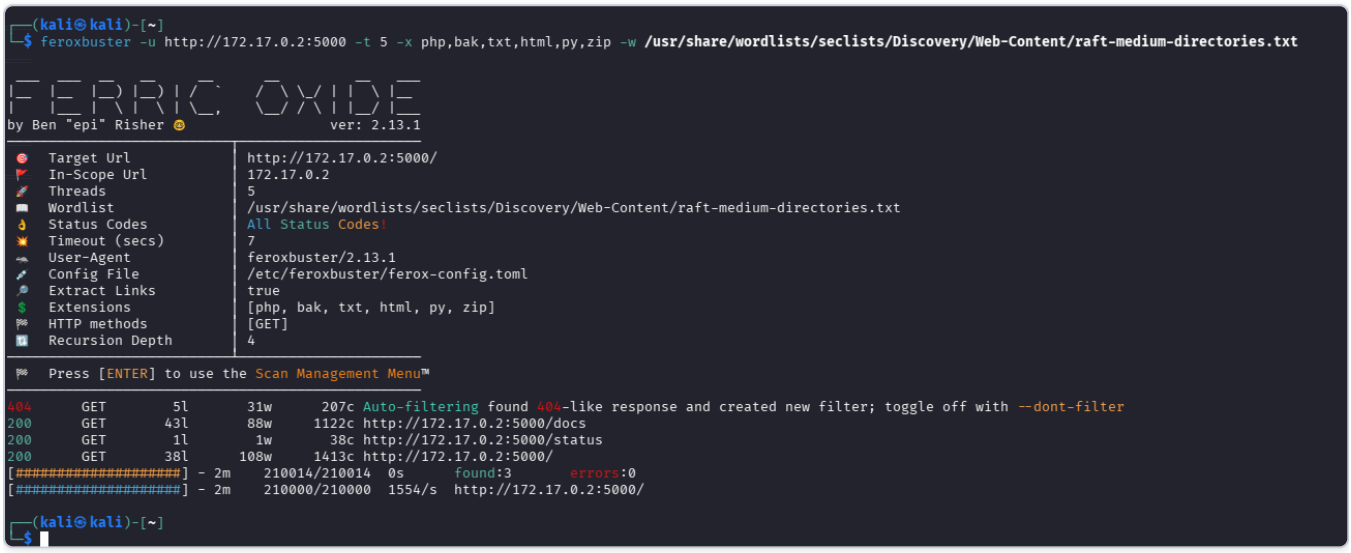


Figura 2. Feroxbuster identifica las rutas /docs, /status y / respondiendo con HTTP 200.

5.3 Análisis del servicio — endpoint de estado

El endpoint `/status` devuelve un objeto JSON que confirma el nombre del servicio y su disponibilidad. Sirve para validar que la aplicación está operativa, pero no expone datos sensibles por sí mismo.

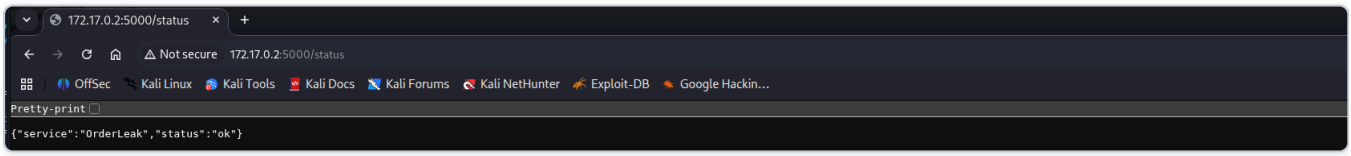


Figura 3. Respuesta de /status: {{"service":"OrderLeak","status":"ok"}}.

5.4 Análisis del servicio — documentación del API

La ruta `/docs` resultó ser el punto de inflexión de la prueba. Expone públicamente la documentación completa del API, revelando el endpoint clave:

- `GET /api/orders/<id>` — «Detalle de un pedido por ID numérico» (con el alias `/api/order/<id>`).

La documentación incluye además un ejemplo de respuesta que confirma dos aspectos críticos: el identificador es **numérico y secuencial** (ejemplo `/api/orders/1`), y cada pedido contiene un campo `owner` (propietario) además de datos de negocio. Esto evidencia que el recurso **está asociado a un usuario concreto**, por lo que debería requerir control de acceso — algo que, como se demuestra a continuación, no existe.

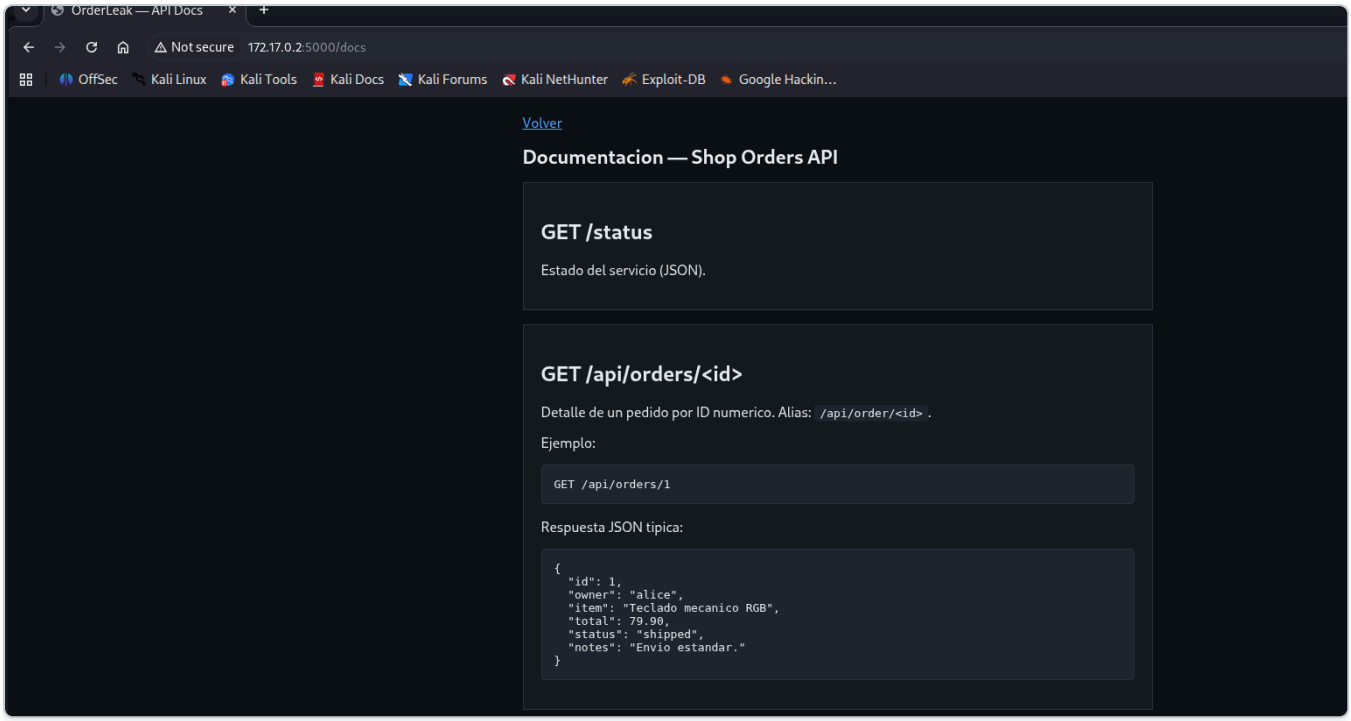


Figura 4. Documentación en /docs: el endpoint GET /api/orders/ acepta un ID numérico y cada pedido tiene un propietario (owner).

5.5 Explotación — autorización rota a nivel de objeto (BOLA / IDOR)

Dado que el identificador es numérico y predecible, y que no se solicita ninguna autenticación, se procedió a **enumerar identificadores** más allá del ejemplo documentado (`id=1`). Al solicitar directamente el pedido `#15`:

```
$ curl http://172.17.0.2:5000/api/orders/15
```

El servidor devolvió, **sin ninguna credencial**, un pedido perteneciente a otro usuario (`owner: "carol"`) marcado explícitamente como `status: "confidential"`. El contenido corresponde a una *«Adquisición clasificada de infraestructura central CISO»* por valor de 4.500 €, e incluye la bandera que valida el compromiso: `BURP{bola_comparer_api}`.

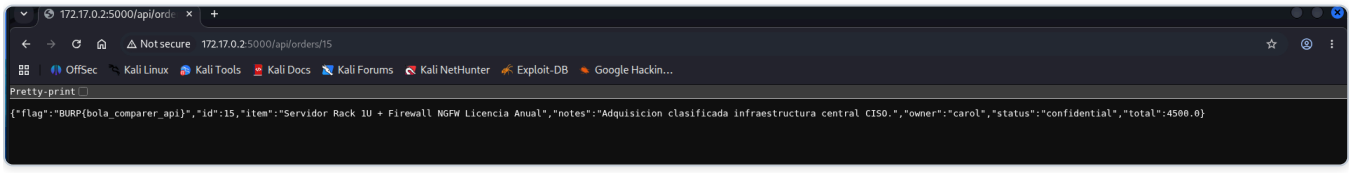


Figura 5. Acceso no autorizado al pedido #15 (owner: carol, status: confidential), con datos clasificados y la bandera BURP{{bola_comparer_api}}.

> **Causa raíz:** el endpoint resuelve el pedido únicamente a partir del ID proporcionado por el cliente y lo devuelve sin verificar *(a)* que exista una sesión autenticada ni *(b)* que el usuario autenticado sea el propietario del recurso solicitado. Es un caso de manual de *Broken Object Level Authorization*.

5.6 Confirmación del compromiso

La introducción de la bandera en la plataforma validó la resolución del laboratorio. El tiempo total invertido fue de **10 minutos y 49 segundos**, demostrando la baja complejidad de explotación de este tipo de fallo.

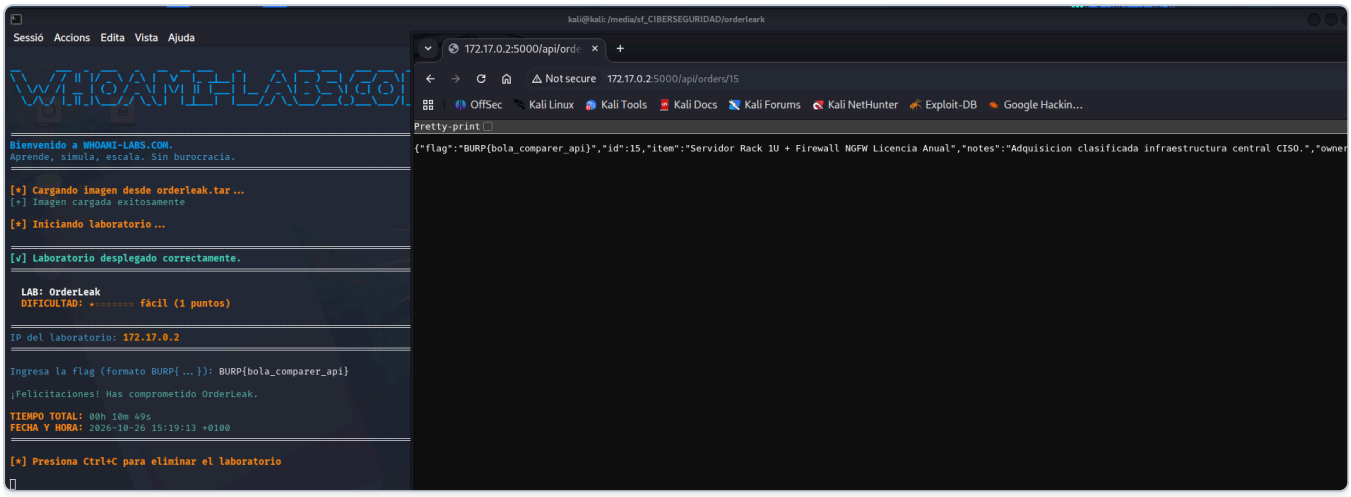


Figura 6. Panel de whoami-labs.com confirmando el compromiso de OrderLeak con la bandera válida (tiempo total: 00h 10m 49s).

6. Ficha detallada del hallazgo H-01

Campo	Detalle
Título	Autorización rota a nivel de objeto (BOLA / IDOR) en `/api/orders/<id>`
Severidad	**ALTA** — CVSS 3.1 Base 7.5
Vector CVSS	`AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`
Clasificación	CWE-639 (Authorization Bypass Through User-Controlled Key) · OWASP API Security Top 10: API1:2023 (BOLA)
Activo afectado	`http://172.17.0.2:5000/api/orders/<id>` (y alias `/api/order/<id>`)
Precondiciones	Ninguna. Acceso de red al servicio; no requiere autenticación.
Impacto	Divulgación no autorizada de datos de pedidos de cualquier usuario, incluyendo información confidencial de negocio (fuga de confidencialidad).

Pasos de reproducción

1. Acceder al endpoint documentado con el ID de ejemplo: `GET /api/orders/1`.
2. Incrementar / enumerar el identificador numérico: `2, 3, …, 15, …`
3. Observar que el servicio devuelve pedidos de otros propietarios sin solicitar autenticación.
4. Recuperar el pedido confidencial: `GET /api/orders/15`.

Impacto en el negocio

Un atacante sin credenciales puede extraer de forma masiva y automatizada la totalidad de la base de pedidos iterando los identificadores. Esto supone la exposición de datos de clientes, importes, descripciones de productos y notas internas, incluyendo material explícitamente clasificado. Además de la pérdida de confidencialidad, en un escenario real implicaría incumplimiento normativo en materia de protección de datos y daño reputacional.

Recomendaciones de remediación

- **Exigir autenticación** en todos los endpoints que sirvan datos de negocio (p. ej. token de sesión o API key).
- **Implementar control de acceso a nivel de objeto:** en cada petición, verificar en el lado del servidor que el usuario autenticado es el propietario del pedido solicitado (`order.owner == current_user`) antes de devolverlo.
- **Sustituir los identificadores secuenciales** por valores no predecibles (UUIDv4) para dificultar la enumeración como defensa en profundidad.
- **No exponer documentación interna del API** (`/docs`) en producción, o protegerla con autenticación.
- **Registrar y limitar (rate-limiting)** los accesos secuenciales a objetos para detectar patrones de enumeración.

7. Cronología de la operación

Hora (CEST)	Actividad
15:08	Inicio del escaneo Nmap; descubrimiento del puerto 5000/tcp.
15:12	Enumeración con Feroxbuster; hallazgo de `/docs` y `/status` .
15:13–15:16	Análisis de la documentación del API; identificación del endpoint de pedidos.
15:18	Explotación del BOLA; acceso al pedido confidencial #15.
15:19	Envío de la bandera y confirmación del compromiso (duración total: 10m 49s).

8. Conclusiones

El servicio OrderLeak presenta un fallo de control de acceso de severidad Alta que permite a cualquier usuario no autenticado acceder a la información de pedidos de terceros. La vulnerabilidad es trivial de explotar y de alto impacto sobre la confidencialidad, un patrón que sistemáticamente encabeza los riesgos de seguridad en APIs. La corrección prioritaria consiste en aplicar autenticación y, sobre todo, **verificación de propiedad del recurso en cada petición**. El resto de medidas (UUIDs, ocultar `/docs` , rate-limiting) refuerzan la defensa en profundidad.

> **Lección clave:** ocultar o aleatorizar un identificador nunca sustituye a una comprobación de autorización en el servidor. La seguridad de un objeto debe verificarse en cada acceso, no asumirse a partir de la dificultad de adivinar su referencia.

9. Referencias

- OWASP API Security Top 10 (2023) — *API1: Broken Object Level Authorization*.
- CWE-639 — *Authorization Bypass Through User-Controlled Key*.
- CWE-284 — *Improper Access Control*.
- MITRE ATT&CK — Reconnaissance (TA0043), Collection (TA0009).
- CVSS v3.1 — Common Vulnerability Scoring System.

Fin del informe · Documento generado para el proyecto formativo «ciber» · Laboratorio autorizado whoami-labs.com · 26/10/2026